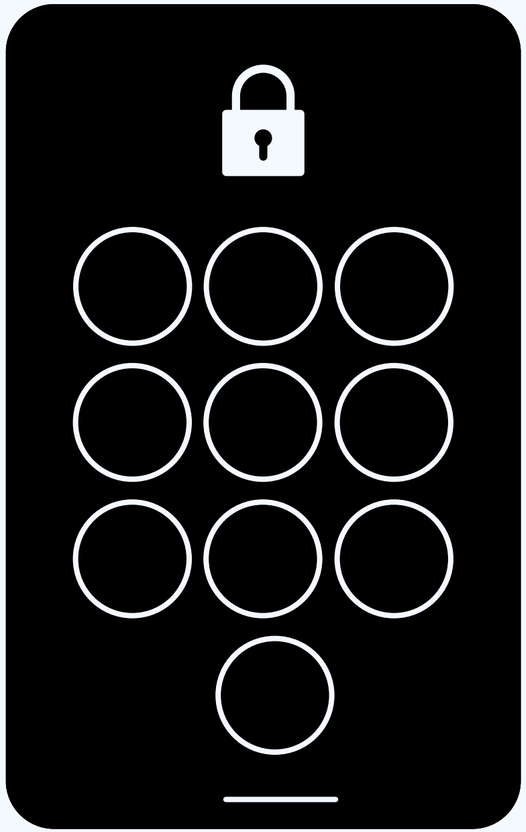
Cyber | Protect | Data | Threat | Security | Attack | Firewall | Malware

SOC ENGAGEMENT CHECKPOINT



Progress PBL Minggu ke-9

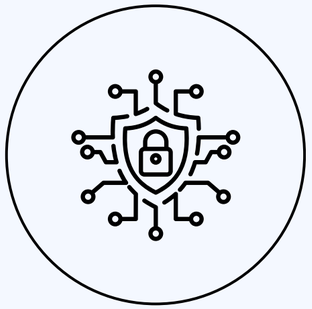
Kelompok 16

SIBER | TEK A

TEAM INTRODUCTION & ROLES



Naiya Humaira R.
J0404241014
Lead



Calvin Umboh
J0404241021
Blue Team



Adiko Abimanyu
J0404241057
Red Team



M Rafiyuda AF
J0404241131
Red Team

KONTEKS PRODUK IOT ASLI

Deskripsi Produk

- Nama Produk: **KABITA (Knowledge-based Animal Breeding & Intelligence Technology Architecture) – Smart Breeder.**
- Ringkasan: Perangkat genggam IoT berbasis mikrokontroler ESP32 yang dilengkapi modul RFID, modul RTC, dan layar TFT. Perangkat ini berfungsi mengidentifikasi ternak kambing melalui ear tag RFID, mencatat riwayat bobot badan, serta memvalidasi silsilah ternak untuk mencegah perkawinan sedarah (inbreeding) secara terintegrasi dengan server basis data

Fokus Skenario SOC

- Manajemen Akses & Otorisasi (RBAC): Memantau serta menegakkan kontrol akses berbasis peran (Role-Based Access Control) pada dashboard web untuk melindungi data silsilah, basis data kambing, dan catatan log dari akses ilegal.
- Keamanan Pembaruan Firmware (OTA): Mengawasi proses Over-The-Air (OTA) update melalui enkripsi dan verifikasi checksum berkas untuk mencegah injeksi firmware palsu atau modifikasi berbahaya pada perangkat
- Pengamanan Komunikasi API: Memantau lalu lintas data antara perangkat ESP32 dan server backend (REST API) guna mendeteksi upaya manipulasi data atau pengiriman permintaan tanpa otentikasi resmi (API Key/JWT).

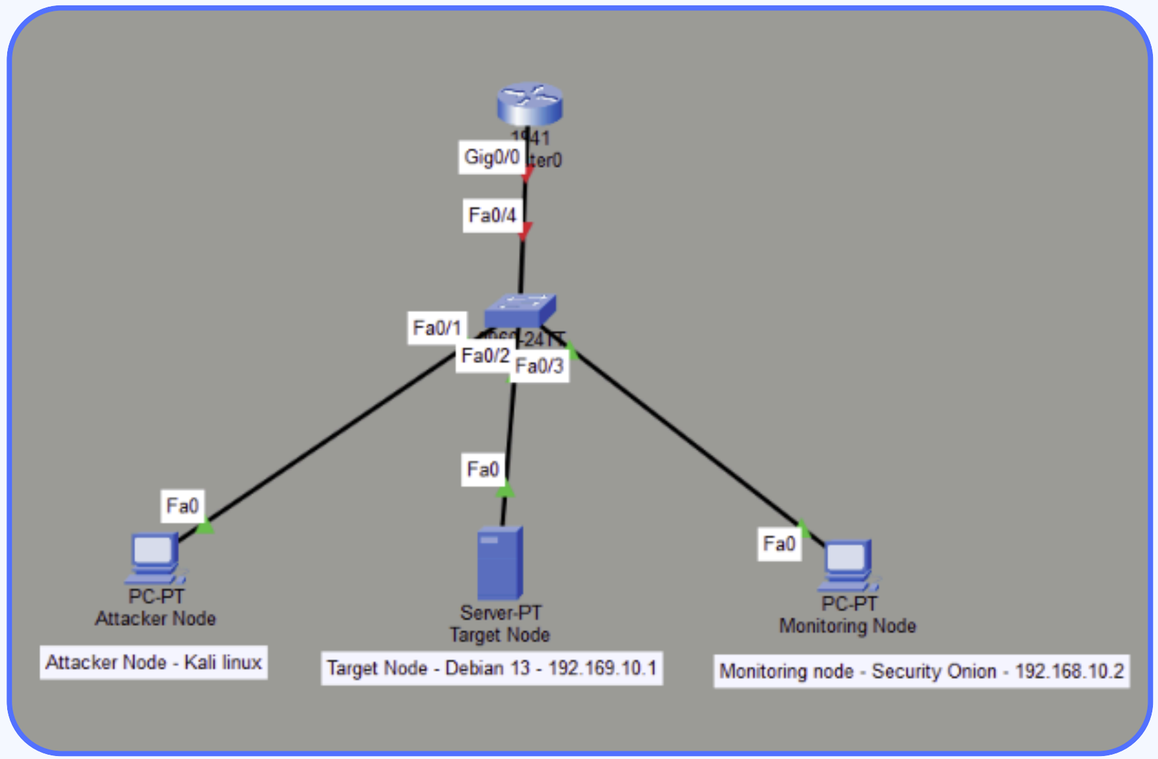
DEKLARASI TECH STACK & REPLIKASI TARGET NODE

Prinsip Replikasi

Mereplikasi teknologi backend asli ke Target Node VM lab untuk menjamin risiko nol (zero risk) pada sistem produksi/mitra

Komponen Teknologi	Tech Stack Proyek Asli	Keterangan	Status Replikasi
OS	Debian 13 (Trixie)	Server host utama untuk deployment aplikasi dan monitoring.	Selesai
Frontend	React.js + TypeScript	Antarmuka pengguna (UI/Dashboard) berbasis komponen modular dan type-safe.	Selesai
Backend & BaaS	Supabase / Supabase Edge Functions	Layanan backend terkelola yang menyediakan autentikasi, REST API otomatis, dan Realtime Webhook.	Selesai
Database	PostgreSQL (Managed by Supabase)	Basis data relasional utama untuk penyimpanan data pengguna dan telemetri.	Selesai
Web Server / Reverse Proxy	Nginx	Reverse proxy, static file server, dan SSL/TLS termination pada Debian 13.	Selesai

ARSITEKTUR JARINGAN SIMULASI & SKEMA IP



Skema IP

- **Target Server**: 192.168.10.1 /24 (OS: Debian 13, Port Switch: Fa0/2) : Menjalankan layanan/aplikasi backend replika.
- **Attacker Node**: DHCP (OS: Kali Linux, Port Switch: Fa0/1) : Digunakan Red Team untuk simulasi pengujian.
- **Monitoring Node:** 192.168.10.2 /24 (OS: Security Onion, Port Switch: Fa0/3) : Digunakan Blue Team untuk monitoring traffic SPAN/mirroring.
- **Infrastruktur**: Switch Catalyst 2960 + Router (Subnet: 192.168.10.0/24)

CHECKLIST PROGRES HARDENING

A — Access & Authentication
B — Service & Attack Surface
C — Data & Application

ID	Kategori / kontrol	Status
A1	SSH key-based authentication	Selesai
A2	SSH tidak menggunakan port default	Selesai
A3	Fail2ban / pembatasan percobaan login	Selesai
A4	Nonaktifkan direct root login	Belum di kerjakan
B1	Nonaktifkan service/port yang tidak dipakai	Selesai
B2	Firewall whitelist port yang diperlukan	Belum di kerjakan
B3	Update & patch OS/paket	Selesai
B4	Hapus akun/kredensial default	Belum di kerjakan
C1	Logging aktivitas mencurigakan	Progress
C2	Secrets melalui environment/secrets manager	Belum di kerjakan
C3	Validasi input API/MQTT	Belum di kerjakan
C4	Least privilege pada user database	Belum di kerjakan

DEMO

```
analyst@SecOnion:~$ ssh calvin@192.168.142.158 -p 2222
The authenticity of host '[192.168.142.158]:2222 ([192.168.142.158]:2222)' can't be established.
ECDSA key fingerprint is SHA256:0lVDJGyxJgf0ksrpmm7kCjPxaKiYTGTTkH2ns6qadYc.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '[192.168.142.158]:2222' (ECDSA) to the list of known hosts.
Permission denied (publickey).
analyst@SecOnion:~$
```

```
PS C:\Users\Calvin> ssh calvin@192.168.142.158 -p 2222
Linux Kelompok6 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Oct 23 09:39:05 2026 from 192.168.10.3
calvin@Kelompok6:~$
```

DEMO

```
competitor@competitor:~$ ssh calvin@192.168.10.1 -p 2222
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
calvin@192.168.10.1: Permission denied (publickey,password).
competitor@competitor:~$
competitor@competitor:~$ ssh calvin@192.168.10.1 -p 2222
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
calvin@192.168.10.1: Permission denied (publickey,password).
competitor@competitor:~$
competitor@competitor:~$ ssh calvin@192.168.10.1 -p 2222
Connection closed by 192.168.10.1 port 2222
competitor@competitor:~$
```

DEMO

```
analyst@SecOnion:~$ nmap 192.168.142.158

Starting Nmap 7.01 ( https://nmap.org ) at 2026-10-22 15:34 UTC
Nmap scan report for 192.168.142.158
Host is up (0.00069s latency).
Not shown: 995 closed ports
PORT     STATE SERVICE
80/tcp   open  http
2222/tcp open  EtherNetIP-1
7070/tcp open  realserver
8080/tcp open  http-proxy
9090/tcp open  zeus-admin

Nmap done: 1 IP address (1 host up) scanned in 0.11 seconds
analyst@SecOnion:~$ nmap 192.168.142.158

Starting Nmap 7.01 ( https://nmap.org ) at 2026-10-22 15:35 UTC
Nmap scan report for 192.168.142.158
Host is up (0.00026s latency).
Not shown: 996 closed ports
PORT     STATE SERVICE
2222/tcp open  EtherNetIP-1
7070/tcp open  realserver
8080/tcp open  http-proxy
9090/tcp open  zeus-admin

Nmap done: 1 IP address (1 host up) scanned in 0.16 seconds
analyst@SecOnion:~$
```

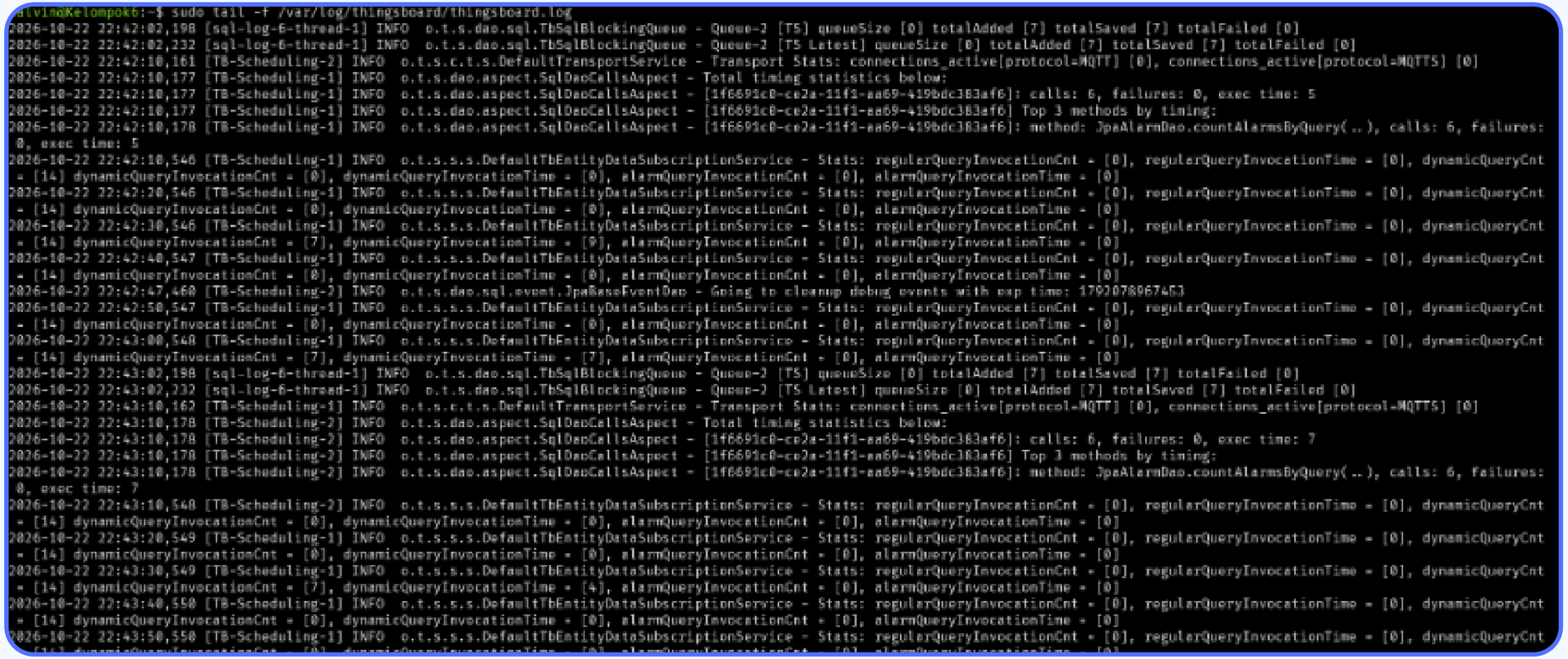
DEMO

```
competitor@competitor:~$ ssh calvin@192.168.10.1 -p 2222
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
calvin@192.168.10.1: Permission denied (publickey,password).
competitor@competitor:~$
competitor@competitor:~$ ssh calvin@192.168.10.1 -p 2222
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
Permission denied, please try again.
calvin@192.168.10.1's password:
calvin@192.168.10.1: Permission denied (publickey,password).
competitor@competitor:~$
competitor@competitor:~$ ssh calvin@192.168.10.1 -p 2222
Connection closed by 192.168.10.1 port 2222
competitor@competitor:~$
```

DEMO

```
calvin@Kelompok6:~$ sudo apt update
Hit:1 https://deb.debian.org/debian trixie InRelease
Hit:2 https://deb.debian.org/debian trixie-updates InRelease
Hit:3 https://deb.debian.org/debian trixie-backports InRelease
Hit:4 https://security.debian.org/debian-security trixie-security InRelease
Hit:5 https://apt.postgresql.org/pub/repos/apt trixie-pgdg InRelease
109 packages can be upgraded. Run 'apt list --upgradable' to see them.
calvin@Kelompok6:~$
```

CHECKLIST PROGRES HARDENING



BASELINE TRAFFIC NORMAL & MONITORING SO

Aktivitas Baseline Traffic

- Pencatatan pola traffic normal antara sensor/dashboard dan Target Node.
- Identifikasi port & protokol aktif yang diizinkan (e.g., HTTP/80, MQTT/1883, SSH/Port Baru)

Live Demo Readiness

Monitoring Node (Security Onion) aktif menangkap lalu lintas data lab

[Persiapan Live Demo: Tampilan Security Onion memantau traffic dummy / ICMP ping test]

RENCANA SKENARIO SERANGAN RED TEAM (FASE 2)

Kategori Serangan	Teknik & Tools	Target di Target Node	Ekspektasi Hasil
Web/API/Protokol IoT	MQTT unauthorized access (MQTT Explorer atau Mosquitto)	MQTT broker dan topic komunikasi antara sensor IoT dengan dashboard	Mengidentifikasi apakah broker mengizinkan klien tanpa autentikasi untuk membaca atau mengirim data.
Exploitation/Akses	Login dan kontrol akses dashboard (browser dan OWASP ZAP)	Halaman login & API	Menemukan kelemahan autentikasi atau otorisasi.
Layer 2 / Jaringan Lokal	Analisis paket yang tidak terenkripsi (Wireshark)	Lalu lintas jaringan perangkat IoT	Mengidentifikasi apakah data sensitif atau informasi sensor dapat dibaca melalui paket jaringan.
Security Misconfiguration	Pemeriksaan header keamanan dan konfigurasi menggunakan OWASP ZAP	Nginx, HTTPS, dan React Dashboard	Mengidentifikasi konfigurasi yang lemah, seperti header keamanan yang belum diterapkan atau pengaturan HTTPS yang kurang tepat.
Brute Force Testing	Simulasi percobaan login berulang dengan akun uji dan pengujian terkontrol	Supabase Auth dan halaman login	Memastikan sistem menerapkan pembatasan percobaan login, penundaan, dan pencatatan aktivitas mencurigakan.
DDoS Resilience Testing	Simulasi beban HTTP terkendali menggunakan k6 pada staging	Nginx, React Dashboard, dan endpoint API	Mengevaluasi kemampuan layanan menangani lonjakan permintaan, kestabilan respons, serta efektivitas pembatasan trafik.

KENDALA & PEMBELAJARAN

Kendala

untuk node nya berada pada 1 device saja karena berada pada 1 laptop untuk untuk virtualisasi dan berada pada jaringan local

Solusi

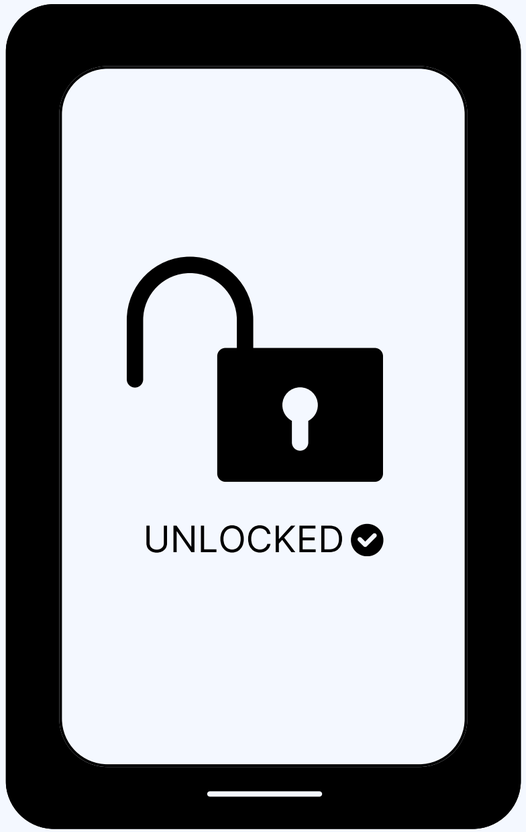
memberikan akses vpn / tunnel yang di pasangkan menuju device laptop , bisa menggunakan tailscale



Cyber | Protect | Data | Threat | Security | Attack | Firewall | Malware

THANKYOU

Stay Safe, Stay Secure



Kelompok 16

SIBER | TEK A